

AnkaSEC

Siber Güvenlik (201)

Azad Kılıç

amondeuss.github.io

1. Alarm Bilgileri

Alarm Adı (Rule Name):

SOC342 - CVE-2025-53770 SharePoint ToolShell Auth Bypass and RCE

Tarih / Saat:

Jul 22, 2025 – 01:07 PM

Hedef Makine (Hostname / IP):

SharePoint01 / 172.16.20.17

2. Olay Analizi (Investigation)

Saldırgan Kaynağı (Source IP):

107.191.58.76

Field	Value
type	Proxy
source_address	107.191.58.76
source_port	25332
destination_address	172.16.20.17
destination_port	443
time	Jul, 22, 2025, 01:07 PM

Şüpheli Aktivite:

Saldırgan, public-facing Microsoft SharePoint sunucusuna özel hazırlanmış bir POST isteği göndererek CVE-2025-53770 (ToolShell) zafiyetini istismar etmiştir.

Çalıştırılan Komut (Command Line)

(Parent Path)



Ve en kritik olarak, saldırganın veri toplamaya geçişi. Saldırgan, MachineKey, Config, ValidationKey vs. olmak üzere, verileri toplamaya başlamıştır. Bu bağlamda saldırgan, sistem bypasslarını gerçekleştirebilecektir.



3. Sonuç ve Aksiyon (Verdict)

Saldırı Başarılı mı?

Evet, başarılı

Durum:

True Positive

Neden?

Senaryo olarak: Saldırgan,

Gerçek exploit (CVE-2025-53770) kullanılmış

Exploit ile girdi: SharePoint üzerindeki zafiyeti kullanarak yetkisiz erişim sağladı.

Komut çalıştırdı: PowerShell üzerinden zararlı kod çalıştırdı.

Web shell yazdı: Sunucuya web shell (spinstall0.aspx) yerleştirerek kalıcılık sağlamış.

Komut çalıştırdı: C# kodu derleyerek payload.exe oluşturdu.

Amacına ulaştı: MachineKey bilgilerini çekti/denedi.

Özetle:

Saldırgan sistemi ele geçirmek, kalıcılık sağlamak ve yetkili erişim elde etmek için çok aşamalı bir saldırı gerçekleştirmiştir.

Bu bulgular saldırının tamamen başarılı olduğunu göstermektedir.

Containment (İzolasyon)

Makine, izole edildi.